

OAST Domain Analysis: CVE-2025-24813 Campaign

Analysis Date: 2026-02-27
Analyst: Orbie
Campaign: CVE-2025-24813 Mass Exploitation
Dataset: 58 sessions, 22 source IPs, 2025-12-07 to 2026-02-27

Extraction Summary

Method	Input	OAST Domains Found
roast pipe (all text fields)	200 unique text values from session search cache	0
roast extract (combined text)	Session + detail + payload text exports	0
extract_oast_file (session search NDJSON)	Raw session search cache	0
extract_oast_file (3 session detail caches)	Raw session detail NDJSON	0
extract_oast_file (3 payload extract caches)	Raw payload extract NDJSON	0
Arkime payload_search: <code>oast.fun</code>	http.requestBody (indexed)	0
Arkime payload_search: <code>oast.live</code>	http.requestBody (indexed)	0
Arkime payload_search: <code>oastify.com</code>	http.requestBody (indexed)	0
Arkime payload_search: <code>interact.sh</code>	http.requestBody (indexed)	0

Method	Input	OST Domains Found
validate_domain_batch_advance d	2 named destination domains	0
PCAP file carving + strings + roast	116 carved files from session PCAP	56 unique domains

Resolution: OST domains were successfully extracted from the session PCAP file (CVE-2025-24813-sessions.pcap) via: (1) `extract_files` MCP carving 116 HTTP objects to disk, (2) `strings` extracting printable text from Java serialized binary payloads, (3) `roast pipe + oast_campaign_analysis` decoding all Interactsh metadata.

Why Arkime MCP failed: The `http.requestBody` indexed field stores only the first bytes of the payload (0xACED magic header). The OST domains are embedded deeper in the Java serialized object graph as `java.net.URL` string fields. Only full payload access (via PCAP) allows extraction.

OST Tag Distribution

GreyNoise applies two OST tags with different detection methods:

Tag	Detection Method	Sessions	Percentage
Contains Well-known Out-of-band Interaction Domain	Exact match against curated public OST domain list	38	65.5%
Generic Contains Well-known Out-of-band Interaction Domain	Pattern-based detection (regex/heuristic)	18	31.0%
No OST tag	Neither detection method triggered	2	3.4%

The "specific" tag indicates the payload contains a domain from a known public OST provider (Interactsh public servers, Burp Collaborator, etc.). The "generic" tag indicates OST-like callback patterns were detected but did not match the curated domain list -- consistent with self-hosted Interactsh instances or private OST infrastructure.

Temporal Phase Transition

A clear operational phase boundary exists at January 22-27, 2026:

Phase 1: Public OAST Infrastructure (Dec 7 - Jan 21)

Date	Sessions	Tag Type
2025-12-07	2	specific
2025-12-20	2	specific
2025-12-21	2	specific
2025-12-22	2	specific
2026-01-02	5	specific
2026-01-03	3	specific
2026-01-04	1	specific
2026-01-05	9	specific
2026-01-06	2	specific
2026-01-17	1	specific
2026-01-18	8	specific
2026-01-21	1	specific
Subtotal	38	

IPs in Phase 1 (10): 112.134.208.214, 104.28.210.246, 138.199.53.249, 105.99.130.198, 213.199.56.60, 185.10.68.229, 107.172.34.27, 37.60.230.90, 216.106.186.24, 185.197.194.11

Transition: No OAST (Jan 22)

Date	Sessions	Tag Type	Source IP	Destination
2026-01-22	1	none	103.35.189.136	testing.noddi.org
2026-01-22	1	none	103.137.185.212	www.stefanobertoli.es

Both sessions target the same path (`/e1pCG4.session`) and are the only sessions in the campaign targeting named domains rather than bare IP addresses. These may represent

exploit delivery without OAST verification, or OAST domains encoded in a way that neither GreyNoise detection method matched.

Phase 2: Private/Custom OAST Infrastructure (Jan 27 - Feb 27)

Date	Sessions	Tag Type
2026-01-27	1	generic
2026-01-28	2	generic
2026-01-29	1	generic
2026-01-30	1	generic
2026-02-04	1	generic
2026-02-06	1	generic
2026-02-07	1	generic
2026-02-22	2	generic
2026-02-23	2	generic
2026-02-25	2	generic
2026-02-26	3	generic
2026-02-27	1	generic
Subtotal	18	

IPs in Phase 2 (10): 194.182.90.104, 190.2.153.222, 40.233.66.153, 168.107.59.85, 38.55.192.204, 109.196.101.80, 4.149.234.135, 4.200.16.222, 83.120.93.0, 83.121.109.70

IP-to-Phase Mapping

Source IP	Phase	OAST Type	Sessions	First Seen	Last Seen
112.134.208.214	1	specific	2	2025-12-07	2025-12-07
104.28.210.246	1	specific	1	2025-12-20	2025-12-20

Source IP	Phase	OAST Type	Sessions	First Seen	Last Seen
138.199.53.249	1	specific	1	2025-12-20	2025-12-20
105.99.130.198	1	specific	2	2025-12-21	2025-12-21
213.199.56.60	1	specific	2	2025-12-22	2025-12-22
185.10.68.229	1	specific	9	2026-01-02	2026-01-04
107.172.34.27	1	specific	11	2026-01-05	2026-01-06
37.60.230.90	1	specific	1	2026-01-17	2026-01-17
216.106.186.24	1	specific	8	2026-01-18	2026-01-18
185.197.194.11	1	specific	1	2026-01-21	2026-01-21
103.35.189.136	T	none	1	2026-01-22	2026-01-22
103.137.185.212	T	none	1	2026-01-22	2026-01-22
194.182.90.104	2	generic	1	2026-01-27	2026-01-27
190.2.153.222	2	generic	2	2026-01-28	2026-01-28
40.233.66.153	2	generic	1	2026-01-29	2026-01-29
168.107.59.85	2	generic	1	2026-01-30	2026-01-30
38.55.192.204	2	generic	1	2026-02-04	2026-02-04
109.196.101.80	2	generic	2	2026-02-06	2026-02-07
4.149.234.135	2	generic	4	2026-02-22	2026-02-23
4.200.16.222	2	generic	2	2026-02-25	2026-02-25
83.120.93.0	2	generic	3	2026-02-26	2026-02-26
83.121.109.70	2	generic	1	2026-02-27	2026-02-27

No IP appears in both phases. Combined with the fact that all 22 IPs use a consistent exploit technique (identical JA4H fingerprint, Content-Range header, Java serialization payload), this indicates either:

1. **Single operator with infrastructure rotation:** One actor rotated both source IPs and OAST callback infrastructure simultaneously around January 22-27

2. **Shared exploit toolkit:** Multiple operators using the same CVE-2025-24813 exploit framework (likely the Metasploit module), with different operators configuring different OAST providers

The Phase 2 shift to "generic" OAST detection is consistent with migration from public Interactsh servers (e.g., [*.oast.fun](#), [*.oast.live](#)) to self-hosted Interactsh instances on custom domains that are not in GreyNoise's curated list.

Destination Host Analysis

39 unique destination hosts across 58 sessions. All but 2 are bare IP addresses.

Named domains (both from transition sessions without OAST tags):

Domain	OAST Validation	Session IP	Note
testing.noddi.org	Not OAST	103.35.189.136	Legitimate domain targeted for exploitation
www.stefanobertoli.es	Not OAST	103.137.185.212	Legitimate domain targeted for exploitation

Neither named destination is OAST callback infrastructure. These are exploitation targets (Tomcat instances) that the campaign is attempting to compromise.

Extracted OAST Domains (from PCAP)

Source: [CVE-2025-24813-sessions.pcap](#) -- 116 HTTP objects carved, [strings](#) + [roast](#) pipeline **Provider:** 100% Interactsh (public servers) -- zero Burp Collaborator, zero custom infrastructure **Total unique domains:** 56 **Unique campaigns:** 22 **Unique machine IDs:** 19 **Unique PIDs:** 25 **Time span:** 2025-12-06 to 2026-02-26 (2.7 months)

TLD Distribution

TLD	Domains
.oast.online	14
.oast.site	12

TLD	Domains
.oast.fun	9
.oast.me	6
.oast.pro	6
.oast.live	5
Total	56 (4 domains use 2 TLDs across campaigns)

All 7 TLDs are official Interactsh public server domains.

Campaign Groupings

Campaign	Domains	Machine ID	PIDs	TLDs	Earliest	Latest
6blda	11	cb:ab:54	24554	oast.online	2026-01-05	2026-01-05
8eo94	8	0e:c2:48	47788	oast.fun	2026-01-18	2026-01-18
0m88j	5	16:42:26	29669	oast.site	2026-01-02	2026-01-02
g9qfq	4	09:d3:f4	63138	oast.pro	2026-02-21	2026-02-21
om88j	4	16:42:26	7106, 51720	oast.site, oast.online	2026-01-03	2026-01-04
bp720	3	79:38:81	13811, 36421, 49179	oast.me, oast.site	2026-02-25	2026-02-26
9kqv0	2	34:9f:c0	49899	oast.site	2025-12-21	2025-12-21
oc7lj	2	0c:3d:67	1064	oast.site	2026-01-28	2026-01-28
ug386	2	d0:1a:0c	7681	oast.online	2025-12-06	2025-12-06
05kjo	2	05:a4:f0	18430	oast.pro	2026-02-25	2026-02-25
dsaia	2	bc:54:95	25840	oast.online	2025-12-22	2025-12-22
gffll	1	0f:7d:6a	57772	oast.live	2026-01-29	2026-01-29
djnqr	1	b3:be:b7	23985	oast.pro	2026-01-17	2026-01-17
49ndh	1	89:bb:62	55486	oast.fun	2026-01-30	2026-01-30

Campaign	Domains	Machine ID	PIDs	TLDs	Earliest	Latest
j6o66	1	66:c1:8c	49786	oast.me	2026-02-04	2026-02-04
grh9o	1	1b:8a:70	14087	oast.live	2026-02-07	2026-02-07
0rh9o	1	1b:8a:70	44409	oast.live	2026-02-06	2026-02-06
da9db	1	aa:4b:57	10189	oast.live	2025-12-19	2025-12-19
rp720	1	79:38:81	27438	oast.me	2026-02-25	2026-02-25
15pqc	1	25:ce:98	25936	oast.me	2025-12-20	2025-12-20
vn6u3	1	f7:37:86	54381	oast.me	2026-01-27	2026-01-27
nmtqe	1	f6:ee:9c	36592	oast.online	2026-01-21	2026-01-21

Cross-Campaign Machine Correlation (Persistent Operators)

3 of 19 machines appear in multiple campaigns, indicating persistent operators reusing infrastructure:

Machine ID	Campaigns	Domains	PIDs	Date Range
16:42:26	0m88j, om88j	9	3 (7106, 29669, 51720)	Jan 2-4, 2026
79:38:81	bp720, rp720	4	4 (13811, 27438, 36421, 49179)	Feb 25-26, 2026
1b:8a:70	0rh9o, grh9o	2	2 (14087, 44409)	Feb 6-7, 2026

- **Machine 16:42:26**: Most prolific. 9 domains across 2 campaigns over 2 days (Jan 2-4). 3 distinct PIDs indicate multiple Interactsh process restarts on the same host.
- **Machine 79:38:81**: 4 PIDs in ~23 hours (Feb 25-26). Rapid PID cycling suggests automated scripting with frequent process restarts.
- **Machine 1b:8a:70**: 2 campaigns on consecutive days (Feb 6-7). Different PIDs confirm separate Interactsh invocations.

All multi-campaign machines are from **Phase 2** (generic OAST tag) except machine 16:42:26 which is from **Phase 1** (specific tag). This further supports the earlier finding that Phase 2 operators show more sophisticated behavior (private OAST infrastructure, more frequent process cycling).

Payload Structure

The Java serialized payloads contain a `java.net.URL` object with the OAST domain as both the `authority/host` field and a full `http://` URL. Example from a decoded payload:

```
None
java.util.HashMap
  java.net.URL
    authority: d5telagff1le3b72d2ugyut7oauqbwrr.oast.live
    file: (empty)
    host: d5telagff1le3b72d2ugyut7oauqbwrr.oast.live
    protocol: http
    -> http://d5telagff1le3b72d2ugyut7oauqbwrr.oast.live
```

This is the standard `java.net.URL` SSRF gadget chain. When Tomcat deserializes the `.session` file, the `java.net.URL.hashCode()` method triggers DNS resolution of the OAST domain, confirming RCE to the attacker.

Revised Phase Analysis

The PCAP extraction **partially contradicts** the earlier Phase 2 hypothesis. All 56 extracted OAST domains use public Interactsh TLDs (`.oast.live`, `.oast.pro`, `.oast.site`, `.oast.fun`, `.oast.me`, `.oast.online`). These ARE in the GreyNoise curated list.

Updated interpretation: The "Generic" tag in Phase 2 may not indicate private OAST infrastructure. Instead, it may reflect:

1. A GreyNoise tagging engine update between Phase 1 and Phase 2 that changed how OAST domains are classified
2. The specific tag matching on the full payload binary, while the generic tag matches on different payload characteristics
3. Subtle differences in how the OAST domain is embedded (e.g., URL-encoded vs plain) that trigger different tag rules

The domain evidence confirms all sessions use the same class of public Interactsh infrastructure across both phases.

Key Findings (Updated)

1. **56 unique OAST domains** extracted from PCAP -- all Interactsh public servers, 7 TLDs
 2. **22 campaigns** from 19 unique machines -- consistent with the 22 source IPs in the campaign
 3. **3 persistent machines** appear in multiple campaigns (16:42:26, 79:38:81, 1b:8a:70)
 4. **java.net.URL SSRF gadget chain**: Standard deserialization-triggered DNS resolution for RCE verification
 5. **No Burp Collaborator**: 100% Interactsh -- tooling is consistent with Metasploit/Interactsh integration
 6. **Phase distinction revised**: Both phases use public Interactsh domains; GreyNoise tag difference is classification-level, not infrastructure-level
-

Domain List

56 unique OAST domains saved to `oast-domains.txt`. All are Interactsh-encoded with decodable metadata (campaign key, machine ID, PID, timestamp, counter).